

● 第一阶段：止血与筑墙（第 1 - 2 周）

目标： 堵住最明显的漏洞，确保如果明天中勒索病毒，公司不会倒闭。

第 1 -2 周：边界恢复与“冷”备份

1. 物理防火墙复活（总部 & 电信机房）

- **动作：** 联系深信服等代理商，确定防火墙购买方案，购买特征库升级授权（IPS、AV 杀毒、URL 过滤）。
- **配置检查：** 确保固件（Firmware）升级到最新稳定版。

2. 实施“离线备份”（Air Gap Backup）

- **原理：** 勒索病毒会加密所有它能通过网络触达的文件。物理断网是唯一的绝对防御。
- **落地：**
 - 购买 1 个 4TB 以上的移动硬盘（企业级机械硬盘）。
 - **周五下午：** IT 人员手动将金蝶数据库备份文件、域控服务器的关键数据拷贝到硬盘 A。

3. 云端端口封锁（阿里云 & 腾讯云）

- **动作：** 登录控制台 -> 安全组（Security Group）。
- **执行：**
 - **封禁高危端口：** 彻底关闭对公网开放的 135, 139, 445 (SMB), 3389 (RDP), 1433 (SQL Server)。
 - **白名单机制：** 只有总部出口 IP 和特定管理员 IP 才能访问管理端口。

第 2 周：密码重置与账号清洗

1. 域控（AD）弱口令清洗

- **背景：** 历史上 80% 的入侵源于弱口令。
- **落地：** 检查域管理员密码（长度 > 12 位，大小写 + 数字 + 符号）。检查是否有类似 `admin`，`123456`，`caiwu` 这种幽灵账号，一律禁用。

2. 金蝶/ERP 数据库账号加固

- **动作：** 检查 SQL Server 的 `sa` 账户密码。很多企业装软件时用的是默认密码，必须修改。

● 第二阶段：制度与演练（第 3 - 4 周）

目标： 建立长效机制，验证备份的有效性。

第 3 周：数据恢复演练（DRP）

- **重要性：** 没有经过恢复验证的备份等于没有备份。
- **落地：**
 1. 找一台闲置服务器或虚拟机。
 2. 从那个“锁在保险柜里的硬盘”中提取上周的财务数据。
 3. 尝试恢复到测试环境中，让财务总监亲自验证数据是否完整、可用。
 4. 记录恢复所需时长（RTO），如果太慢，需要优化备份方式。

第 4 周：行为审计与长效运维

1. 启用上网行为管理审计

- **动作：** 每周分析防火墙的病毒日志。
- **重点关注：** 是否有人在半夜有大量数据外传？是否有内网主机频繁尝试连接外部的高危 IP？



资源与预算预估（参考）

项目	预估成本 (RMB)	说明
深信服防火墙续保	1 万 - 3 万/年	取决于设备型号和功能模块，必须投入
移动硬盘 (4TB * 1)	~1,500	用于离线冷备份，性价比最高的保险
IT 人力投入	内部团队	需 1-2 名网络工程师重点跟进